Pickle Rick

Offensive Security Write-up



Autor: Gabriel de Vargas

Data: 30 de agosto de 2026

Sinopse

A sala Pickle Rick, disponível na plataforma TryHackMe, é um desafio de enumeração e exploração em um ambiente Linux. O percurso documentado neste write-up utiliza Nmap e GoBuster para identificar serviços e diretórios, seguido da análise do código-fonte e do arquivo robots.txt para obter acesso ao painel web. A navegação pelo sistema permite recuperar três respostas do desafio, e a etapa final utiliza uma configuração permissiva de sudo para acessar o diretório /root.

1. Enumeração

A enumeração inicial foi realizada com o Nmap para identificar portas abertas e serviços disponíveis no alvo.

```
$ nmap -sV <IP_DA_MAQUINA>
# -sV: detecta as versões dos serviços identificados
```

A varredura identificou as portas 22 (SSH) e 80 (HTTP) abertas, além de indicar que o alvo utiliza um sistema Linux. Em seguida, foi utilizada a ferramenta GoBuster para enumerar caminhos disponíveis no servidor web. Foram encontrados:

```
/robots.txt
/login.php
/portal.php
/assets
```

2. Exploração

A inspeção do código-fonte da página inicial revelou o nome de usuário R1ckRul3s. A análise dos caminhos encontrados também levou ao arquivo /robots.txt, cujo conteúdo forneceu a senha utilizada no painel de autenticação.

Com o usuário e a senha em mãos, foi possível autenticar-se em /login.php e obter acesso ao painel de comandos em /portal.php.

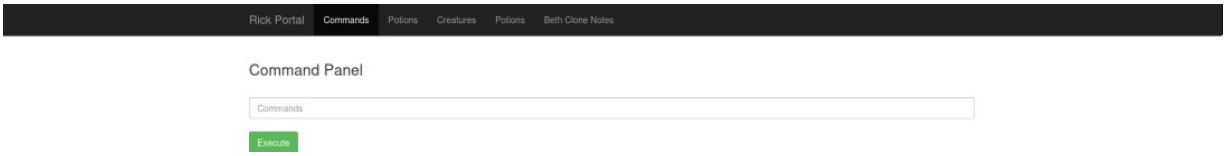


Figura 1 — Painel de comandos após a autenticação no portal.

O painel permitia executar comandos no sistema e serviu como ponto de partida para a navegação pelos diretórios e a recuperação das respostas do desafio.

3. Navegação pelo Sistema

Com acesso ao painel, o comando ls foi utilizado para listar o conteúdo do diretório atual. Entre os arquivos exibidos estava Sup3rS3cretPickl3Ingred.txt, além de diretórios e arquivos relacionados à aplicação.

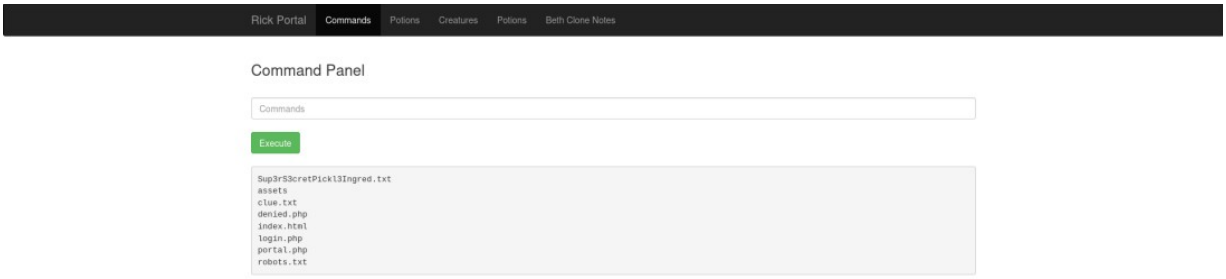


Figura 2 — Listagem do diretório atual no painel de comandos.

A primeira tentativa de leitura com cat não foi permitida pelo painel. Como alternativa, foi utilizado o comando tac, que não estava bloqueado e exibiu a primeira resposta do desafio:

```
$ tac Sup3rS3cretPickl3Ingred.txt
mr. meeseek hair
```

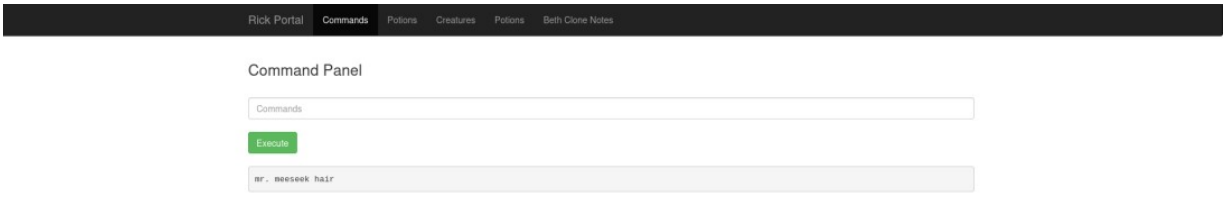


Figura 3 — Primeira resposta exibida pelo comando tac.

Na sequência, foi consultado o diretório /home. A listagem revelou os diretórios rick e ubuntu.

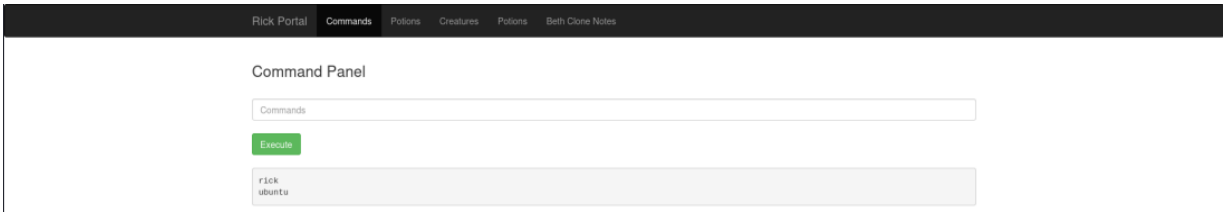


Figura 4 — Diretórios encontrados em /home.

A navegação para o diretório de rick revelou uma pasta chamada second ingredients, que indicava a localização da segunda resposta.

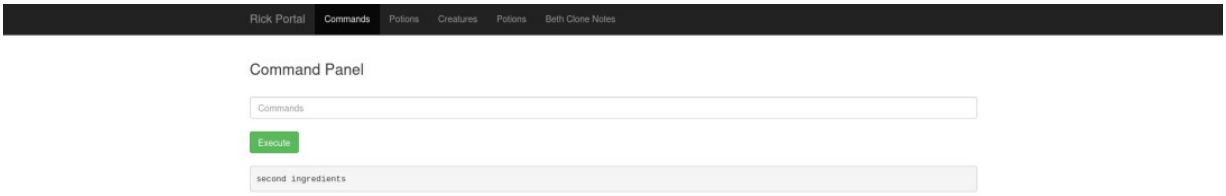


Figura 5 — Diretório second ingredients encontrado dentro de /home/rick.

Ao consultar o conteúdo desse diretório, foi recuperada a segunda resposta do desafio:

```
$ ls /home/rick/second\ ingredients
1 jerry tear
```

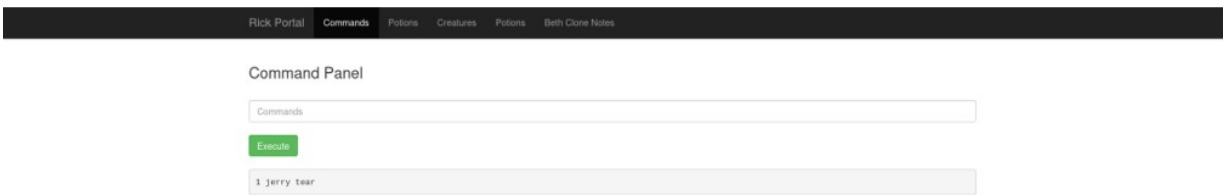


Figura 6 — Segunda resposta exibida no painel.

4. Escalação de Privilégios

Para obter a terceira e última resposta, foi necessário verificar as permissões de sudo do usuário atual, www-data. O comando sudo -l mostrou que esse usuário podia executar qualquer comando como qualquer usuário, sem solicitar senha (NOPASSWD: ALL).



Figura 7 — Resultado de sudo -l indicando permissão NOPASSWD: ALL.

Com essa permissão, foi possível listar o conteúdo do diretório /root e identificar o arquivo 3rd.txt, além do diretório snap. Em seguida, o arquivo 3rd.txt foi consultado com privilégios de root, revelando a terceira resposta:

```
$ sudo cat /root/3rd.txt
3rd ingredients: fleeb juice
```

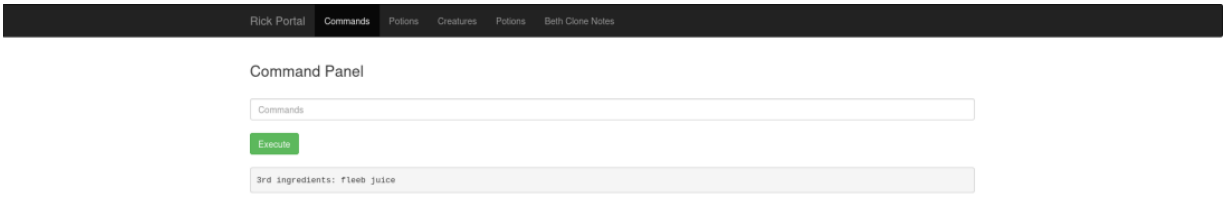


Figura 8 — Terceira resposta recuperada do arquivo 3rd.txt.

Conclusão

O desafio Pickle Rick demonstra como a enumeração de serviços e diretórios pode revelar informações úteis para o acesso inicial a uma aplicação web. A análise do código-fonte e de robots.txt forneceu as credenciais do painel, enquanto a navegação pelo sistema permitiu recuperar as respostas solicitadas. Por fim, a configuração de sudo concedida ao usuário www-data representou uma falha crítica de privilégio, pois permitia executar comandos como root sem autenticação.